

Juan Pablo de Legarreta

NETC 180 – Information Risk Management

Module Eight Assignment

Risk Analysis

One of the risks that RG Enterprises faces is from its use of black Henna paste in its shirt dyeing. A risk analysis was done on this practice and its ramifications. According to the risk matrix from this risk analysis, the use of black Henna paste is considered a medium risk given its high likelihood but marginal impact. Several mitigation strategies were proposed in light of this risk and a few were strongly recommended to mitigate the fallout from the use of the dye as well as preventing future infractions. With their implementation, there will be several ways to check for their efficacy. Part of the efficacy of these mitigation strategies will be to try and minimize any residual risk after their implementation, and there are many additional controls that can help further reduce residual risk as well.

Recommended Security Controls

The recommended mitigation strategies regarding the use of the black Henna paste in the merchandise dyeing were the following:

1. Put out a press release with an apology announcing a recall of the merchandise
2. Offer to replace the merchandise or offer in-store credit for new purchases to customers
3. Reach out directly to customers making the original accusations and do some damage control
4. Replace the dye with an alternative
5. Take advantage of the shift to rebrand the products and processes as organic, earth-friendly, etc. to push past the situation

While many of these mitigation strategies do not perfectly correspond with the CIS 18 Security Controls, many of them have parallels with the cybersecurity controls. Many of the CIS

Security Controls also provide additional strategies to follow up on and verify the efficacy of the mitigation strategies themselves as well as minimize residual risks.

Assessing Efficacy of Security Controls

1. Put out a press release with an apology announcing a recall of the merchandise

The simplest way to gauge the efficacy of this strategy is to observe the public reaction to the press release. The more positive or cooperative the response, the better the strategy will have worked. News coverage can also be a good barometer on how the press release is received and can be a great medium to participate in to do some further damage control. Customer behavior on social media praising or denouncing the company as well as their participation and interaction with the company will also be indicators of whether this control works. If people send their shirts back in and participate in the recall, reach out to the company, or post positive messages on social media, the strategy can be seen as effective. The natural follow-up to this instance of the mitigation strategy would be to put in place guidelines, scripts, or procedures on how to handle merchandise recalls, problems, or bad press. Creating and refining such a guide would help to minimize residual risks from bad press in the future.

This mitigation strategy would create policy and procedures that are closely related to CIS Security Control 17 – Incident Response Management. Just as incident response relies on playbooks and policies, reacting to a public scandal like this greatly benefits from a well-defined set of steps to take to mitigate the damage. Though more incidents would be required to test the efficacy of the created procedures and strategies, the goal of creating them in the first place is to also make the company more readily aware of potential pitfalls in the future that it can prevent as opposed to react to. Having a robust Incident Response will help minimize residual risks.

2. Offer to replace the merchandise or offer in-store credit for new purchases to customers

Offering a replacement or in-store credit to customers is a way to right the wrong and earn their trust back. Measuring the effectiveness of this strategy is two-fold: tracking both the percentage of customers that purchased the Henna-dyed shirts who reach out to get their replacement or in-store credit, and how many of those customers make future purchases. The more customers that engage with the company to get a replacement or credit and who make more purchases, the more successful the strategy will be. This mitigation strategy is a version of CIS Control 17 – Incident Response Management because it is a strategy that aims to increase incident response capability through policies, plans, and procedures. (Center for Internet Security)

A robust Incident Response requires thoughtful procedures that are effective and the training of staff to carry them out. Incident Response relies on good planning and policies in place. In the case of the Henna paste use, keeping the customer first and making sure to mitigate the fallout of the skin dyeing is the best way to respond to the incident. Preventing future incidents is important but does not take away from the value of having a good way to handle incidents if they end up occurring in the future, which reduces residual risk.

3. Reach out directly to customers making the original accusations and do some damage control

This mitigation strategy aims to control the narrative at the source of the accusations. If RG Enterprises wants to try and keep the word from spreading and get ahead of the story or other accusations, it would do well to speak directly to the customers to get a sense of what the grievances are and try to handle them in such a way that the customers leave with a positive view

of the company and the incident. Measuring the success of this strategy would require monitoring social media platforms, news outlets, and possibly blogs to make sure that no more negative comments are made about the company and no more accusations are levied. If it is determined that the complaints have come to an end, then the next (more positive) indicator to look for is a reversal of tone – perhaps a disgruntled customer takes their post back and updates the story with the positive interaction with the company, or a news story updates the older news with a more positive profile of the company and how it handled the incident. When the tone surrounding the incident shifts to a positive light, the strategy can be determined to have succeeded.

This strategy is also like CIS Control 17 – Incident Response Management. How RG Enterprises handles this PR crisis will help it handle others in the future. The strategy, in a way, is also like CIS Control 10 – Malware Defenses, though instead of keeping malware from spreading on its network, it is keeping bad press from spreading in people’s social networks. Being able to have procedures that dispel negativity and build trust in its customer base would be an excellent control to have in place at RG Enterprises.

4. Replace the dye with an alternative

Replacing the black Henna paste with an alternative pigment or dye would immediately stop the staining of customers’ skin due to the Henna paste. Of course, the replacement would also have to be non-staining, which could be verified with research and testing. The research part of this control would be very important, as RG Enterprises cannot afford to pick a dye at random and test them until they find one that works. Making sure to use the dye as instructed to keep customers and employees safe can be a result of good training, which is similar to CIS Control 14 – Security Awareness and Skills Training. Providing a solid training program for employees

on properly mixing and using the new dye will be a key part of keeping skin-staining incidents down to a minimum and reduce the residual risk of carelessness in operations.

In addition to training, testing the dye and the merchandise periodically is a great strategy to make sure the alternate is safe and is a kind of auditing. Auditing is a powerful tool that can check the efficacy of any control or mitigation strategy. (Poremba) This practice is also very similar to CIS Control 7 – Continuous Vulnerability Management. Just as cyber vulnerability management requires testing and observation of systems, ‘auditing’ the effects of the new replacement dye can assure that the risk of staining customers’ skin is reduced or even eliminated. This can be set up with company policies and quality control procedures that keep employees accountable to best practices and assure the quality of the finished product.

5. Take advantage of the shift to rebrand the products and processes as organic, earth-friendly, etc. to push past the situation

The root of this mitigation strategy is in CIS Control 1 – Inventory and Control of Enterprise Assets. Taking the Henna paste out of the process and adding a new dye is already a must – why not take full control of the situation and turn the reputation of the organization around with a choice to have an organic, eco-friendly dye? By doing this, the operations side of the organization gets to put a tighter control on its merchandise quality, manufacturing process, and even potentially increase its revenues (organic or eco-friendly branding could justify an increase in price for merchandise!) This is an excellent example of taking control of enterprise assets and its procedures.

To measure the success of this mitigation strategy, one would have to track the public response to the company – if there is positive buzz on social media, in the customer base, or on the news, the strategy can begin to be successful. The true measure of success for this strategy,

however, would be a growth of customer base and perhaps the advent of a new type of customer – one concerned with the environment or more willing to pay for higher quality merchandise. If a new customer base arises, more revenue will come to the company. Increased revenue will also be a great indicator of whether this strategy was successful or not.

Conclusion

Implementing these five risk mitigation strategies can ease RG Enterprise's consequences for using the Henna paste in their shirt-making. With parallels in the CIS Controls, these mitigation strategies will have immediate, measurable effects that will attest to their efficacy. The best way to judge their lasting effectiveness is a total reduction of incidents down to zero, though this is a best-case scenario. More than likely, the lasting sign of the efficacy of these mitigation strategies will be positive rebounds from any incidents that may occur in the organization's future. By measuring the immediate effects of these controls and also keeping a watchful eye for their lasting effects, RG Enterprises can be assured of the efficacy of these suggested controls and greatly minimize any residual risks in their future.

Bibliography

Center for Internet Security. "The 18 CIS Controls." *CIS*, 2024, www.cisecurity.org/controls/cis-controls-list.

Hyperproof Team. "Residual Risk Defined: Expert Strategies for Management and Mitigation." Hyperproof, 22 Feb. 2024, <https://hyperproof.io/resource/residual-risk-definition/>. Accessed November 11, 2024.

Poremba, Sue. "Residual Risk in Cyber Security: What It Is & Best Practices." Verizon Enterprise, www.verizon.com/business/resources/articles/s/what-is-residual-risk-in-cyber-security/. Accessed November 11, 2024.